Sample. Startup Alpha is a fictional company. The findings show the format and level of detail of a real report; they describe no existing company.

Technical and security due diligence: Startup Alpha

Merchant payments by QR and mobile money · Dakar and Abidjan · €600,000 seed round · review carried out 2–13 November 2026 · report for the investment committee of [Fund]

1. Summary

Opinion: invest, with 3 conditions. The product works and the architecture will carry the volume planned for 24 months. Two flaws, however, could cost real money or customer data before the team grows: they must be fixed before disbursement.

Level	Finding	Section
● Critical	Mobile-money payment notifications are not verified: a fake payment can be recorded as real.	5.1
● Critical	No backup has ever been restored in a test; the last full backup is 41 days old.	4.2
● To fix	API keys (payment aggregator, SMS provider) are present in the code repository's history.	5.2
● To fix	Only one developer knows and can access the production system.	7.1
● To fix	No filing has been made with ARTCI or Senegal's CDP, although the app processes phone numbers and purchase histories.	6.1
● Sound	Simple architecture (one API, one PostgreSQL database, one task queue), suited to 50,000 active merchants.	3
● Sound	The merchant app's offline mode is well designed: no duplicate sales in our tests.	3

2. Conditions before disbursement

1. **Verify the signature of every payment notification** and reject unsigned ones (estimated effort: 2 days).

2. **Restore a full backup in a test environment**, time the recovery, and automate a daily backup (3 days).
3. **Revoke and replace every exposed key**, then move them to a secrets vault (1 day).

We can check these three points in half a day, on evidence, before signing.

3. Architecture and room to grow

One API (Python), a managed PostgreSQL database, a task queue for notifications, and two Flutter apps (merchant and customer), all hosted with a cloud provider in Europe. The heaviest queries (daily reports) use suitable indexes; at 10 times today's volume, only the report calculation will need to move to a background task.

4. Infrastructure and operations

4.1 Deployment

Automatic deployment from the main branch, with automated tests on every change (58% coverage). No staging environment: changes go straight to production.

4.2 Backups

● **Critical**

The provider's automatic backups are on, but they are kept for 7 days and no restore has been tested. The last manual full backup dates from 3 October. An accidental deletion discovered after a week would be irreversible today.

4.3 Costs

About €410 a month for 3,200 active merchants. The fastest-growing cost is SMS (61% of the total): worth watching in the business plan.

5. Security

5.1 Payment notifications

● **Critical**

The endpoint that receives payment confirmations from the operator does not check the request's signature. Anyone who knows the address can send a fake confirmation, which the app records as a received payment and rewards with loyalty points. We found this by reading the code, without exploiting it.

5.2 Secrets

- To fix

Three keys appear in the repository's history (payment aggregator, SMS, file storage). They were removed from the current code but are still valid.

5.3 Access

Named cloud accounts, but two of the three have no two-factor authentication. The app's admin account is shared between the founder and the developer.

5.4 Dependencies

Four libraries have known vulnerabilities, one of them high severity (handling of uploaded files). A simple update, with no code change expected.

6. Data protection

6.1 Filings

- To fix

The app processes phone numbers, purchase histories and the approximate location of merchants in Côte d'Ivoire and Senegal. No prior filing has been made with ARTCI (Law 2013-450) or the CDP (Law 2008-12). Hosting in Europe is a transfer of data out of the country, which may need authorisation. To be confirmed by local legal counsel.

6.2 Consent

Customers' consent to the loyalty programme is collected and time-stamped, and can be withdrawn in the app. A strength to keep.

7. Team and ownership

7.1 Key person

- To fix

One employed developer wrote 87% of the code and alone holds production access. There is no operations documentation. We recommend a second, emergency access held by the founder, and a written recovery procedure.

7.2 Ownership

The code repository, cloud accounts and app-store accounts belong to the company. The domain name is registered in the founder's personal name: it should be transferred.

7.3 Licences

No licence incompatible with closed commercial use was found.

8. Fix plan

Fix	When	Effort
Verify the signature of payment notifications	Before disbursement	2 days
Test a restore; daily backups kept 30 days	Before disbursement	3 days
Revoke and replace exposed keys	Before disbursement	1 day
Two-factor authentication on every cloud account	Within 30 days	½ day
Update the 4 vulnerable dependencies	Within 30 days	1 day
ARTCI and CDP filings; opinion on the data transfer	Within 90 days	Legal counsel
Emergency access and written recovery procedure	Within 90 days	2 days
Staging environment	Within 6 months	3 days

9. Scope and limits

Read-only access to the code repository, cloud console and admin interface, 2–13 November 2026; a 90-minute interview with the founder and the developer. Non-intrusive security tests only: no penetration test, no customer data viewed. This report describes the system as it stood on those dates; it is not legal advice.